CyberRiskGuardian Student Lab Workbook

Twelve labs on the MediBec teaching case — Education Package 1.0

Marc-André Léger, PhD

October 2026

Contents

How to use this workbook 1

Lab 0 — Getting started 2

Lab 1 — Organizational context and crown jewels 3

Lab 2 — Risk appetite 4

Lab 3 — Writing risk scenarios 5

Lab 4 — Quantifying a scenario 7

Lab 5 — CVSS v4.0 for a scenario 8

Lab 6 — Calculating and interpreting risk 10

Lab 7 — Treatment, shared controls and residual risk 11

Lab 8 — Sensitivity and uncertainty 12

Lab 9 — Key risk indicators 13

Lab 10 — The management memorandum 14

Lab 11 — Security operations evidence (optional, desktop track) 14

Lab 12 — From risk to policy and audit 15

Appendix A — Formula sheet 16

Appendix B — Parameter anchors and valid ranges 16

Appendix C — Templates 16

Appendix D — Answers to the self-check questions 18

Appendix E — Glossary 19

How to use this workbook

These labs teach you to run a scenario-driven cybersecurity risk assessment with CyberRiskGuardian (CRG), one step at a time, on a single fictional organization: **MediBec**, a private medical centre with ten clinics in Quebec.

MediBec's complete worked assessment is published with CyberRiskGuardian, so you can check your work against it. Your graded assignment will use a *different* case.

Each lab gives you its objectives, the time it takes, what you need, the steps, the deliverable and three questions to check your understanding. Answers to those questions are in Appendix D. Work in the tool track your instructor chose:

- **Track A — Claude**: the CyberRiskGuardian plugin or project in Claude.
- **Track B — Desktop**: the CyberRiskGuardian desktop application in your browser.
- **Track C — Excel**: the CyberRiskGuardian workbook (Analyse, S1–S10, M1–M10 sheets).

Where a step differs by track, it is marked **[A]**, **[B]** or **[C]**.

Five rules for every lab

1. **Use the case as your source of facts.** If you need a fact the case does not give, say so, state a reasonable assumption and explain what would change if it were wrong.
2. **Label what you estimate.** Every number you or an AI tool estimate carries **Analytical estimate — validation required**. Every missing fact carries **Information gap — organizational validation required**. Every choice that belongs to management carries **Management decision required**.
3. **Let the engine calculate.** Final numbers come from the verified calculator (desktop application, `crg_calc.py` or the recalculated workbook), never from an AI's arithmetic.
4. **Verify AI output.** AI tools invent standards, control identifiers, laws, statistics and CVSS vectors that look right. Check each one against a primary source before you use it.
5. **Protect data.** Do not paste confidential material into an AI service unless you are authorized to. MediBec is fictional and safe to use.

Lab 0 — Getting started

Objectives: install or open your track; confirm that the calculation engine is correct; learn the three markers.
Time: 30 minutes.

Steps

1. Install or open your track.
   - **[A]** In Claude Code: `/plugin install cyberriskguardian --marketplace ITriskMgr/CyberRiskGuardian`, then `/plugin install crg-governance-textbook --marketplace ITriskMgr/CyberRiskGuardian`. Run `pip install cvss "mcp>=1.2"` once, restart and approve the `crg-calculator` server.
   - **[B]** Unzip the desktop application, then double-click `start.command` (macOS, Linux) or `start.bat` (Windows). Leave the terminal window open. The application opens at `http://localhost:8099`. Always use this same address: your work is stored by your browser for that exact address.
   - **[C]** Open the blank model `templates/CyberRiskGuardian_Excel_Model_Blank_v2-4e.xlsx` (or the copy your instructor gave you); save a copy under your team's name. It opens in manual calculation mode: press **F9** (Formulas → Calculate Now) before reading any number.
2. Verify the engine.

- **[A]** Run `python3 crg_calc.py medibec30.json` from the plugin's `crg-quantify/scripts` folder against the MediBec example. It must print **total estimated 84,491** and **residual 41,104**.
- **[B]** The bottom of the left sidebar must read **engine verified · 84,491 / 41,104**.
- **[C]** Your instructor will give you one scenario's inputs and expected result; enter them and compare.

3. **[B]** Open the MediBec workspace, then **Process** (first menu item). Read the thirteen steps of a complete assessment.
4. Read the three markers in the "Five rules" above. Find one example of each in the MediBec example deliverables or workspace.

Deliverable: a screenshot of the verified engine (or your calculator output), with your name and the date.

Check your understanding

0.1. Why should you not rely on any number until the engine has been verified?

0.2. In the desktop application, why might your workspaces seem to disappear if you open the application at `127.0.0.1:8099` instead of `localhost:8099`?

0.3. Which marker would you use for "MediBec's EHR vendor is not named in the case"?

Lab 1 — Organizational context and crown jewels

Objectives: describe MediBec's mission, critical processes and dependencies from the case; identify its crown-jewel assets; separate facts from assumptions. **Time:** 60 minutes. **Input:** MediBec business case, sections 3 to 5.

Background

A risk assessment starts from the business, not from a list of threats. You need to know what MediBec does, which processes matter most, which assets those processes depend on, and what you do *not* know yet.

Steps

1. Read sections 3 to 5 of the case. List the facts you will rely on, each with its section number. Example: *"10 clinics in Montreal, Quebec City, Gatineau and Saguenay (s.3)."*
2. Fill the context table below. Keep each cell under 40 words.

Context element	MediBec (with source)
Mission	
Sector and size	
Critical business processes	
Critical systems and applications	
Infrastructure and cloud	
Sensitive information	
Suppliers and partners	

Context element	MediBec (with source)
Legal and regulatory context (as the case states it)	
Availability requirements	
Existing controls	
Incident history	
Cybersecurity capacity	

3. Trace one chain: **Objective → Process → Primary asset → Supporting assets → Dependencies → Consequence if lost.** Example start: *Continuity of care → clinical documentation → EHR → identity, Montreal data centre, WAN → …*
4. Identify **five or six crown jewels**: the assets or services whose loss would most harm the mission. For each, give a business owner, the importance of confidentiality, integrity and availability (High / Very high), and its main dependencies.
5. List at least three **information gaps** (facts you would need but the case does not give) and two **assumptions** you are making, each with its marker.
   - **[A]** Ask the assistant to run the context intake on the case document. Compare its crown jewels with yours; keep only what the case supports.
   - **[B]** Organization → Workspaces → *New workspace* (type *Classroom business case*), drop the case document, tick *Extract the profile & appetite* and *Then extract the crown jewels*, choose **Rules only (no AI, offline)**. Review every proposed value and its tag (FACT, INFERENCE, ASSUMPTION, EXTERNAL, UNKNOWN). Resolve the UNKNOWN values you can from the case.

Deliverable: the context table, one dependency chain, the crown-jewel list and the gaps-and-assumptions list (two pages maximum).

Check your understanding

1.1. Why is “identity and remote access” a crown jewel even though it does not hold patient data itself?

1.2. The case says MediBec has seen “multiple unsuccessful attack attempts since 2020”. Is that a fact, an inference or an assumption? What can you *not* conclude from it?

1.3. Name one dependency that is a single point of failure for several crown jewels.

Lab 2 — Risk appetite

Objectives: estimate and justify a cybersecurity risk appetite on a 0–1 scale; distinguish appetite, tolerance and risk score. **Time:** 45 minutes. **Input:** case section 8 (risk appetite statement); your Lab 1 context.

Background

The appetite expresses how much cybersecurity risk management is prepared to pursue or retain. CRG uses these anchors:

Value	Meaning
0.1–0.2	Very high risk aversion — very low appetite

Value	Meaning
0.3	Low appetite
0.5	Risk-neutral, moderate appetite
0.7	Relatively high appetite
0.8–0.9	Very high appetite

Values of 0.1 and 0.9 are extremes that should not normally be used.

Steps

1. Find what the case states. MediBec's appetite statement gives a **normalized tolerance of 0.40**, low appetite for patient safety, health-data confidentiality, compliance and public trust, and escalation thresholds (residual above 0.25 for executive review, above 0.40 for Board acceptance).
2. Consider the factors: sector, mission, sensitivity of information, regulatory requirements, potential impact on individuals (patients), dependence on technology, financial capacity, tolerance for disruption, reputation.
3. Decide on a value. You may keep the case's 0.40 or propose another value; either way, justify it in five to eight sentences. The published MediBec assessment used **0.30** (an analyst estimate below the stated 0.40, because of patient-safety and health-data sensitivity). Explain whether you agree.
4. Record the value with its marker: if it differs from the case, it is an **Analytical estimate — validation required**, and the final choice is a **Management decision required**.
    - **[A]** Ask: *"Estimate MediBec's cybersecurity risk appetite on a 0–1 scale, with the rationale."* Compare the answer with the case statement; do not accept a value you cannot justify yourself.
    - **[B]** Organization → Profile & appetite: enter the appetite and its rationale. The *appetite estimator* at the bottom proposes a value from ticked factors.
    - **[C]** Enter the appetite in the Analyse sheet (cell E14 in the standard template).

Deliverable: the appetite value and its rationale (half a page).

Check your understanding

2.1. Is an appetite of 0.30 "more cautious" or "less cautious" than 0.40? What happens to tolerated risk when the appetite falls?

2.2. Why is it an error to leave the workbook's default appetite without a reason?

2.3. The appetite is 0.30 and a scenario's estimated risk is 6,467. Can you say whether the scenario is acceptable from these two numbers alone? Why not?

Lab 3 — Writing risk scenarios

Objectives: write scenarios as complete causal chains; generate 20 candidates and select the 10 most material; avoid duplicates and threat labels. **Time:** 90 minutes. **Input:** Lab 1 context and crown jewels; case section 9 (scenario library) for inspiration only.

Background

A scenario is not a threat name. It is a causal chain:

> ***Threat source or event → vulnerability or weakness → affected asset or process → cybersecurity event → organizational consequence.***

Use this sentence pattern:

> *Because [threat source or event] can exploit [weakness] affecting [asset or process], [undesirable event] may occur, resulting in [consequences] and impairing [objective].*

Weak: "Ransomware." **Strong:** "A ransomware affiliate uses stolen VPN credentials and the absence of MFA on remote access to encrypt the clinical scheduling servers, stopping appointments at all sites for several days."

Steps

1. Generate **20 candidate scenarios** for MediBec. Spread them across: identity, ransomware, cloud, third parties, insiders, applications and APIs, infrastructure, endpoints, medical devices, privacy, fraud, resilience and recovery. Use at least three generation strategies: from the crown jewels (top-down), from the weaknesses the case reveals (bottom-up), from threats active against healthcare (threat-driven).
2. For each candidate write one sentence in the causal pattern and tag the CIA dimension it mainly affects.
3. **Screen** the candidates. Score each from 1 to 5 on four criteria: business criticality, threat relevance, exposure, potential impact. Add an **escalation flag** where the scenario could affect patient safety, destroy backups, or cause catastrophic data loss — such scenarios cannot be dropped for low probability alone.
4. **Consolidate.** Merge variants of the same exposure (for example three phishing scenarios that differ only by department).
5. **Select ten.** Do not just take the ten highest totals: check that the portfolio covers different assets, actors and consequences, and that no single technique dominates. For each selected scenario, answer: *Why this one, and not the strongest scenario you left out?*
6. Develop **one** selected scenario fully: name, stakeholders, threat source, initiating event, vulnerabilities, affected assets and processes, existing controls (only those the case evidences), event sequence (five to eight steps), consequences (confidentiality, integrity, availability, operations, finance, regulatory, reputation, privacy, safety), assumptions.
    - **[A]** `/select-scenarios` runs the full screening procedure (Sections A–E). Or ask for 20 candidates, then challenge each: *"Which step of this chain does the case evidence?"*
    - **[B]** Batch scenarios → *Threat patterns × assets* → tick the patterns, *Tick crown jewels + 5 most critical*, set *Number of candidates* to 20, **Generate candidates**. Edit names and statements in the grid, tick ten and **Add selected to the register**. Optionally: Ontology · CRGO → *Suggest scenarios* to see related library scenarios.

Deliverable: the 20 candidates with scores, your ten selected with a one-line justification each, and one fully developed scenario (Appendix C template).

Check your understanding

3.1. Rewrite "Data breach at MediBec" as a causal-chain scenario.

3.2. Why must a low-probability scenario that could destroy all backups stay on the list?

3.3. Two of your scenarios are “phishing of clinic staff” and “phishing of billing staff”. Should you keep both? What would justify keeping them separate?

Lab 4 — Quantifying a scenario

Objectives: estimate the six CRG parameters for one scenario, each with a value, rationale, evidence and confidence. **Time:** 75 minutes. **Input:** your developed scenario from Lab 3 (or MediBec S1, below).

The six parameters

Symbol	Name	What it measures	Low (≈0.2–0.35)	High (≈0.65–0.85+)
Pb(A)	Threat presence	Will this threat act against MediBec in 12 months?	Rare actor, needs special position	Observed or constant (phishing, scanning)
Pb(ψ,A)	Exploitation	If it acts, will it get through this weakness, given existing controls?	Strong, evidenced controls	Weakness evidenced (MFA push approved, alert closed)
δe	Expected damage	Harm reasonably expected	Limited records, one site	Network-wide, several sites
δm	Maximum damage	Harm plausible at worst	—	Safety impact, catastrophic data loss
θ	Resilience	Ability to prevent, detect, contain, respond, recover and keep operating (higher is better)	No tested recovery, small team	Tested recovery, 24×7 detection
μ(E)	Criticality	Importance of the affected service to the mission	Supporting process	Mission-critical (care delivery, identity)

Rules: every value is between 0 and 1; δm is at least δe; θ is never zero; Pb(A) and Pb(ψ,A) are estimated separately; μ(E) is not a second damage estimate.

Worked example — MediBec S1

S1: Credential compromise of clinical administrator accounts through phishing and MFA fatigue. A financially motivated actor phishes clinic administrators with an EHR-themed lure, captures credentials and obtains approval of an MFA push prompt, gaining remote access to the EHR, billing and administrative systems.

Parameter	Value	Rationale (abridged)	Evidence	Confidence
Pb(A)	0.85	Phishing is constant and attempts are increasing; lures already observed	Case s.5; exercise evidence	Medium
Pb(ψ,A)	0.55	Push MFA is bypassable by fatigue; no conditional access or macro blocking evidenced	Exercise evidence	Low
δe	0.55	Access to a subset of records; containment possible if detected	Case s.3	Medium

Parameter	Value	Rationale (abridged)	Evidence	Confidence
δm	0.85	Full EHR access, or a pivot to ransomware	Case s.3	Medium
θ	0.40	Two-person security team; alert triage weak; incident response untested	Case s.4	Medium
μ(E)	0.85	Identity is the gateway to every crown jewel	Case s.4	High

All six values are **Analytical estimates — validation required.**

Steps

1. Take your developed scenario from Lab 3.
2. Estimate each of the six parameters. For each, write one or two sentences of rationale, cite the case section (or label the gap) and give a confidence: High, Medium or Low.
3. Name the **two or three values you are least sure of**, and the evidence that would settle them (an interview, a log review, a restore test, a vendor contract…).
   - **[A]** Ask the assistant for a *parameter critique* of your values. Accept a change only if you can defend it yourself.
   - **[B]** Scenario editor → *Quantification*: enter value, rationale, evidence and confidence for each parameter.
   - **[C]** Enter the values in the scenario's S sheet; recalculate (F9).

Deliverable: the parameter table for your scenario, with the most uncertain values identified.

Check your understanding

4.1. Why would merging Pb(A) and Pb(ψ,A) into one "likelihood" double-count?

4.2. A teammate sets θ = 0.90 "because MediBec has firewalls and antivirus". What is wrong with that reasoning?

4.3. Why must δm be at least δe?

Lab 5 — CVSS v4.0 for a scenario

Objectives: score one defined vulnerability with CVSS v4.0 Base; understand what CVSS does and does not measure. **Time:** 60 minutes.

Background

CVSS (Common Vulnerability Scoring System) measures the **technical severity of one vulnerability**. CRG uses the CVSS v4.0 Base score as a multiplier in the risk formula. It is not a measure of organizational risk: a high CVSS does not mean the highest business risk.

For non-technical scenarios (phishing, insider misuse, fraud, governance gaps), score a **representative weakness** (for example "single-channel push MFA") and label the score *limited applicability* — or explain why CVSS does not apply.

The Base metrics

Group	Metric	Values
Exploitability	Attack Vector (AV)	Network, Adjacent, Local, Physical
	Attack Complexity (AC)	Low, High
	Attack Requirements (AT)	None, Present
	Privileges Required (PR)	None, Low, High
	User Interaction (UI)	None, Passive, Active
Vulnerable system impact	Confidentiality, Integrity, Availability (VC, VI, VA)	High, Low, None
Subsequent system impact	Confidentiality, Integrity, Availability (SC, SI, SA)	High, Low, None

Worked example — MediBec S1

Representative weakness: push-based MFA without number matching on remote access.

`CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:A/VC:H/VI:H/VA:N/SC:H/SI:L/SA:L` → **9.3 (Critical)**

Metric	Value	Why
AV	Network	The remote-access portal is reached over the internet
AC	Low	No special conditions beyond the phishing kit
AT	None	No deployment-specific prerequisite
PR	None	The attacker starts with no account
UI	Active	A user must enter credentials and approve the push
VC / VI	High / High	Full control of the compromised session
VA	None	Availability of the gateway is not affected
SC	High	Access extends to patient records in the EHR
SI / SA	Low / Low	Limited downstream integrity and availability effect

Steps

1. Define the single vulnerability your scenario depends on, in one sentence.
2. Choose each Base metric and justify it in one line.
3. Compute the score with a calculator — never estimate it by eye.
   - **[A]** `/crg-calc` or the `cvss4_score` tool of the `crg-calculator` server.
   - **[B]** Tools → *CVSS v4.0*: paste or build the vector, then save it to the scenario.
   - **[C]** Use the FIRST CVSS v4.0 calculator and enter the score in the Analyse sheet; keep the vector string next to it.

4. Write one sentence on the limits of the score for your scenario.

Deliverable: the vector, the score and the metric justifications.

Check your understanding

5.1. Change S1's User Interaction from Active to None. Would you expect the score to rise or fall? Why does that make sense?

5.2. Why should you keep the full vector string, not just the score?

5.3. Give one MediBec scenario for which CVSS has only limited applicability, and explain.

Lab 6 — Calculating and interpreting risk

Objectives: calculate estimated and tolerated risk; read the result against tolerance; explain what drives the verdict. **Time:** 45 minutes.

The formulas

```
Estimated risk  Re = Pb(A) × Pb(ψ,A) × CVSS × ((δe + δm) / 2) × μ(E) ÷ θ × Factor
Tolerated risk  Rt = Pb(A) × Pb(ψ,A) × CVSS × Appetite × μ(E) ÷ θ × Factor
```

The factor (1,000 in the MediBec assessment) only scales the numbers. Risk scores are **relative indicators** for comparison and prioritization, not dollars and not predictions of loss.

Worked example — MediBec S1 (appetite 0.30, factor 1,000)

```
Re = 0.85 × 0.55 × 9.3 × ((0.55 + 0.85) / 2) × 0.85 ÷ 0.40 × 1,000 = 6,467
Rt = 0.85 × 0.55 × 9.3 × 0.30 × 0.85 ÷ 0.40 × 1,000          = 2,772
Pre-treatment ratio = Re ÷ Rt = 2.33  →  above tolerance before treatment
```

Notice that the pre-treatment ratio is simply **average damage ÷ appetite** = 0.70 ÷ 0.30 = 2.33. Everything else cancels.

Steps

1. Calculate Re and Rt for your scenario by hand (show each multiplication), then with the engine. The two must agree to the nearest unit.
   - **[A]** `/crg-calc` with the six parameters, the CVSS vector, the appetite and the factor.
   - **[B]** Risk calculator → click your scenario's row to see each step of the formula.
   - **[C]** Recalculate (F9); read columns L (estimated) and M (tolerated) of the Analyse sheet. **Do not rely on the red cell colour**: compare L with M numerically.
2. Compute the pre-treatment ratio and check it equals average damage ÷ appetite.
3. Repeat with the case's stated appetite (0.40). What changes and what does not?
4. **[B]** Look at the whole MediBec register (30 scenarios). Rank by estimated risk, then by pre-treatment ratio. Why do the two rankings differ?

Deliverable: your calculation shown step by step, the engine's result and a three-sentence interpretation.

Check your understanding

6.1. Scenario X has Pb(A) = 0.9 and scenario Y has Pb(A) = 0.2. All their other parameters are equal. Which has the higher estimated risk? Which has the higher pre-treatment ratio?

6.2. What happens to Re and Rt if you change the factor from 1,000 to 10,000? To the ratio?

6.3. Why is "estimated risk = 6,467" not a dollar amount?

Lab 7 — Treatment, shared controls and residual risk

Objectives: design a treatment package tied to the causal chain; estimate probability and impact reductions; calculate residual risk; avoid double-counting shared controls. **Time:** 90 minutes.

The formulas

```
Mitigated risk = Re × Probability reduction × Impact reduction
Residual risk  = Re − Mitigated risk
Ratio          = Residual ÷ Tolerated
```

Read the ratio as: **below 0.90** below tolerance · **0.90–1.10** approximately at tolerance · **above 1.10** above tolerance.

Mitigation is **multiplicative**: 80% probability reduction and 80% impact reduction remove 64% of the risk. A package that reduces only probability, or only impact, mitigates nothing under this convention. To bring a scenario below tolerance you need P × Q ≥ 1 − appetite ÷ average damage.

Worked example — MediBec S1

Package: phishing-resistant MFA and conditional access (I01), privileged access management (I02), 24/7 managed detection and response (I03), awareness (I12). Probability reduction 0.80, impact reduction 0.75.

```
Mitigated = 6,467 × 0.80 × 0.75 = 3,880
Residual  = 6,467 − 3,880       = 2,587
Ratio     = 2,587 ÷ 2,772        = 0.93  →  approximately at tolerance
```

Check: 1 − 0.30 ÷ 0.70 = 0.571; P × Q = 0.60 ≥ 0.571, so the residual is just inside the "approximately at" band.

Steps

1. For your scenario, list **three to five measures**. For each one, say: which step of the causal chain it interrupts; what it adds beyond controls that already exist; its owner; its one-time and recurring cost (CAD, one 12-month horizon); its time to benefit.
2. Estimate the package's probability reduction and impact reduction (each between 0 and 1) and justify them.
3. Calculate mitigated and residual risk and the ratio.
4. **Shared controls.** Identify which of your measures also serve other scenarios. Split their cost across those scenarios (an equal split is acceptable) and note that the portfolio total counts each initiative once.
5. If the scenario is still above tolerance: state the options — mitigate harder, **transfer** (insurance, contract), **avoid** (stop the activity), or **accept** formally — and who must decide.
    - **[B]** Risk mitigation → *Proposals* or *Control catalogue*; set costs and rp / ri; **Apply**. Recommendations → *Treatment need* shows the verdict for every scenario.

- **[C]** Select controls in the M sheet. **Warning:** the template sums control coefficients (default 0.06 each), so about twenty controls exceed 1 and residual risk *rises*. Keep each reduction within 0–1.

Deliverable: the treatment table, the residual calculation and the decision required.

Check your understanding

7.1. A package has probability reduction 0.90 and impact reduction 0.00. What is the mitigated risk? What does that tell you about the package design?

7.2. MFA serves seven MediBec scenarios and costs $180,000 once. How should its cost appear in each scenario and in the portfolio?

7.3. Why can recommending a control "the organization already has" never reduce risk?

Lab 8 — Sensitivity and uncertainty

Objectives: test how the conclusion changes when your estimates change; identify the decisions that depend on uncertain values. **Time:** 45 minutes.

Background

Your parameters are estimates. The question is not "what is the exact risk?" but "does the decision change if I am wrong?" CRG's convention builds three cases: shift Pb(A), Pb(ψ,A), δe and δm by ∓0.10 / ±0.10, θ by ±0.10 / ∓0.10, and both reductions by ±0.10 / ∓0.10, keeping every value within 0.05–0.99.

Worked example — MediBec S1

Case	Estimated	Tolerated	Residual	Ratio	Verdict
Lower (optimistic)	3,202	1,601	752	0.47	Below
Central	6,467	2,772	2,587	0.93	Approximately at
Higher (pessimistic)	13,017	4,881	7,094	1.45	Above

The verdict changes across the range: S1 is a scenario where **better evidence is worth paying for** (for example, testing whether users approve MFA push prompts) before or alongside the investment.

Steps

1. Build the lower, central and higher cases for your scenario.
2. Does the verdict change? If it is "above" even in the lower case, the scenario needs transfer or formal acceptance, not just more spending.
3. Identify the single parameter whose change moves the result most. **[B]** Forecasts → *Drivers* (tornado chart); *Monte Carlo* turns your confidence levels into ranges.
4. Write two sentences for management: what you are confident about, and what evidence would change the recommendation.

Deliverable: the three-case table and the two-sentence statement.

Check your understanding

8.1. In the S1 example, which management decision would change between the lower and the higher case?

8.2. A forecast gives a narrow interval. Does that mean your estimates are right?

8.3. Why does lowering θ raise both estimated and tolerated risk, but leave the ratio unchanged?

Lab 9 — Key risk indicators

Objectives: define measurable KRIs that tell management whether a risk is moving. **Time:** 45 minutes.

Background

A KRI is useful only if someone can measure it, from a named source, on a schedule, against thresholds that trigger action.

Worked example — MediBec

KRI	Risk addressed	Measure	Source	Owner	Frequency	Target	Warning	Critical
KRI-01 % privileged and remote-access accounts on phishing-resistant MFA	S1, S8, S9	FIDO2 accounts ÷ in-scope accounts	Identity provider report	Cybersecurity lead	Monthly	100%	< 95%	< 85%
KRI-05 Crown-jewel backup restore-test success within RTO	S2, S3, S10	Successful tests ÷ tests run	Backup platform, DR records	CIO (Infrastructure)	Quarterly	100%	< 95%	< 80%

Steps

1. Define **three KRIs** for your top scenarios, with every column of the table above.
2. For each KRI, state what management should do when it crosses the warning threshold.
3. **[B]** KRI dashboard → *Record a measurement*. After four readings, Forecasts → *KRI projections* says whether a threshold will be crossed.

Deliverable: three complete KRIs.

Check your understanding

9.1. What is wrong with the KRI “security is improving”?

9.2. Why does a “lower is better” indicator need its thresholds written with “greater than”?

9.3. How many readings does the desktop application need before it projects a KRI trend, and why does it refuse with fewer?

Lab 10 — The management memorandum

Objectives: write a one-page, decision-oriented memo for senior management. **Time:** 60 minutes.

What a strong memo does

- **Leads with the decision** management must take.
- Says how many scenarios are above tolerance **before and after** treatment.
- Gives the **cost of the recommended portfolio** against the budget context.
- States the **residual risk** that remains and who must formally accept it.
- Names the **two or three key uncertainties** and the next steps.
- Does **not** restate tables. It agrees with the workbook to the unit.

MediBec reference points

The published 30-scenario assessment found: after treatment, 12 scenarios above tolerance, 11 approximately at and 7 below; total estimated risk 84,491 against residual 41,104 (a 51% reduction); current cybersecurity spend about 0.9% of the IT budget, below the 4% floor of the budget guideline. *Do not copy these figures into your own case.*

Steps

1. Draft the memo with the Appendix C template.
2. Exchange memos with another team. Each reviewer answers: *What exactly am I being asked to approve? Is the cost clear? Which number would I challenge?*
3. Revise.
   - **[A]** `/qc-review` runs an independent quality review of your memo; `check_labels.py` lists missing markers.
   - **[B]** Governance → *Quality review* before you export anything.

Deliverable: a one-page memo.

Check your understanding

10.1. Why should the first paragraph of the memo state the decision rather than the method?

10.2. Your memo says “residual risk 41,104” and your workbook says 41,140. What should you do?

10.3. Who formally accepts a residual risk that stays above tolerance?

Lab 11 — Security operations evidence (optional, desktop track)

Objectives: connect security-operations evidence to risk scenarios without turning alerts into incidents or confidences into probabilities. **Time:** 120 minutes. **Requires:** the desktop application with the MediBec simulation pack loaded by your instructor.

Steps

1. SIEM → *Overview*: set the as-of date to **9 October 2026**.
2. Work through the ten exercises your instructor assigns (EX-01 to EX-10) in SIEM and SOAR: triage order, a true positive closed as benign, coverage gaps, silent telemetry, TLP restrictions, an indicator with confidence 95, a case that may or may not be an incident, actions without valid approval, playbook readiness, detection gaps.
3. Batch scenarios → *From security operations (SIEM & SOAR)*, as of 9 October. **Record the evidence on S2.** Open S2 in the Scenario editor: the *Security-operations evidence* card shows it, and **no parameter has changed**.
4. Decide, as a team, whether the evidence justifies changing Pb(A), Pb(ψ,A) or θ for S2. Write the rationale. Then run Governance → *Quality review*.

Deliverable: answers to the assigned exercises and the S2 rationale.

Check your understanding

11.1. An indicator carries a source confidence of 95. Can you set Pb(A) = 0.95? Why not?

11.2. What turns a SOAR case into an incident?

11.3. Why does a detection rule whose required telemetry is silent not count as coverage?

Lab 12 — From risk to policy and audit

Objectives: use your risk results to justify a security policy and to prioritize a risk-based audit plan. **Time:** 90 minutes (two parts).

Part 1 — From risk to audit

1. Take the five highest-residual MediBec scenarios. For each, name the **auditable entity** (a process, system or supplier) and the **key control** the treatment depends on.
2. For one key control, design two tests: a **test of design** (is the control built to work?) and a **test of operating effectiveness** over a period (did it work?). State the population, period, sampling unit, method and sample size.
3. Propose one data analytic (for example: terminated employees compared with active accounts) with the data, the query logic and the data-validation steps.

Part 2 — From risk to policy

1. Write the sentence: *"MediBec needs an Identity and Access Management policy because ___, and it will be successful when ___."* Use S1 and your results.
2. Write five numbered policy statements. Each names an actor, uses **must** or **must not**, and states an outcome that can be tested. Put technical values (password length, review intervals) in a named *standard*, not in the policy.
3. Define one KPI for the policy with target, owner, data source and frequency.

Deliverable: the audit test design and the five policy statements with one KPI.

Check your understanding

12.1. Why is “the auditor confirmed that an access-review policy exists” not evidence that access reviews work?

12.2. Rewrite as a testable statement: “Appropriate security controls should be used for remote access.”

12.3. Where should “passwords must be at least 14 characters” be written, and why?

Appendix A — Formula sheet

```
Estimated risk  Re = Pb(A) × Pb(ψ,A) × CVSS × ((δe + δm) / 2) × μ(E) ÷ θ × Factor
Tolerated risk  Rt = Pb(A) × Pb(ψ,A) × CVSS × Appetite × μ(E) ÷ θ × Factor
Mitigated          = Re × Probability reduction × Impact reduction
Residual           = Re − Mitigated
Ratio              = Residual ÷ Rt
Cost-effectiveness = (Re − Residual) ÷ Cost × 1,000   (risk units removed per $1,000)

Simplifications worth remembering
Pre-treatment ratio = ((δe + δm) / 2) ÷ Appetite
Post-treatment ratio = ((δe + δm) / 2) × (1 − P × Q) ÷ Appetite
Below tolerance requires  P × Q ≥ 1 − Appetite ÷ ((δe + δm) / 2)
```

Classification: ratio < 0.90 below · 0.90–1.10 approximately at · > 1.10 above.

Budget guideline (CRG): cybersecurity spend of **12%** of the total IT budget (salaries included) at an appetite of 0.30 or below, **7.8%** at 0.50, **4%** at 0.70 or above, linear in between.

Appendix B — Parameter anchors and valid ranges

Parameter	Valid range	Low	Moderate	High
Pb(A)	0–1	Rare actor or event	Plausible for the sector	Observed or constant
Pb(ψ,A)	0–1	Strong, evidenced controls	Partial or unknown controls	Weakness evidenced
δe, δm	0–1, δm ≥ δe	Limited records, one site	Material, several sites	Network-wide, safety, catastrophic loss
θ	> 0 to 1	Weak: no tested recovery	Partial	Tested recovery, 24×7 detection
μ(E)	0–1	Supporting process	Important process	Mission-critical
CVSS	0–10	—	—	—
Reductions	0–1 each	—	—	—

Appendix C — Templates

C.1 Scenario development template

Field	Content
ID and name	

Field	Content
Causal statement (one or two sentences)	
Stakeholders	
Threat source	
Initiating event	
Vulnerabilities or predisposing conditions	
Affected assets	
Affected business processes	
Existing controls (with evidence)	
Event sequence (5–8 steps)	
Consequences: C, I, A, operations, finance, regulatory, reputation, privacy, safety	
Assumptions and information gaps (with markers)	
Why this scenario? (relevance, evidence, asset, weakness, consequence, why it beats the unselected ones)	

C.2 Management memorandum template

To: *[Executive]* · ***From:*** *[Team]* · ***Date:*** · ***Subject:*** *Decision required — cybersecurity risk treatment portfolio*

Decision requested. *[One or two sentences: what to approve, at what cost, by when.]*

Why now. *[How many scenarios exceed tolerance before treatment; the two or three that matter most, in business terms.]*

Recommended portfolio. *[The initiatives, total one-time and recurring cost, compared with the budget context.]*

Result. *[How many scenarios are below, at and above tolerance after treatment; what residual risk remains.]*

Residual risk to accept. *[Which scenarios, who must formally accept them —* ***Management decision required****.]*

Key uncertainties and next steps. *[The estimates to validate; the evidence to collect; the date of the next review.]*

C.3 Generative AI acknowledgement

I/We used [tool name and version] to [purpose: for example brainstorm risk scenarios, propose parameter rationales, check grammar]. I/We verified all outputs against the case and against primary sources, recomputed every number with the CyberRiskGuardian engine, edited the text, and take responsibility for all content. [Or: No generative AI tools were used in this work.]

Appendix D — Answers to the self-check questions

Lab 0. 0.1 An unverified engine may compute differently from the reference implementation; any number it produces could be wrong without warning. 0.2 The browser stores workspaces per exact address; `127.0.0.1:8099` and `localhost:8099` are different addresses. 0.3 **Information gap — organizational validation required.**

Lab 1. 1.1 Every clinical and administrative service depends on it; its compromise opens access to all other crown jewels. 1.2 It is a stated fact of the case. You cannot conclude that controls stopped the attempts, that logs are sufficient to prove they failed, or that no attempt succeeded undetected. 1.3 The Montreal data centre and WAN hub, or the identity/directory service.

Lab 2. 2.1 More cautious. Tolerated risk falls in proportion to the appetite, so more scenarios exceed it. 2.2 The default is not the organization's appetite; leaving it unexplained means the tolerance test has no basis. 2.3 No. You need the tolerated risk for that scenario (which depends on its own parameters) and, after treatment, the residual risk.

Lab 3. 3.1 Example: "An external actor exploits a publicly exposed cloud storage location used for medical-image transfer, which lacks access restrictions and logging, to download imaging files with patient identifiers, causing a reportable privacy breach, notification costs and loss of patient trust." 3.2 Because the impact could be catastrophic (no recovery after a destructive attack); low-probability, high-consequence scenarios carry an escalation flag and may need investigation rather than exclusion. 3.3 Usually merge them. Keep them separate only if the assets, consequences, controls, owners or treatment decisions differ materially (for example, billing staff can divert payments — a fraud consequence clinic staff do not create).

Lab 4. 4.1 Pb(A) already captures whether the threat acts; if your "likelihood" also includes that the attack succeeds, then multiplying it by Pb(ψ,A) counts the same uncertainty twice. 4.2 Owning controls is not resilience. θ measures demonstrated ability to prevent, detect, contain, respond, recover and keep operating; the case shows a two-person team, weak triage and untested recovery. 4.3 Maximum damage is the plausible worst case; the expected case cannot exceed it.

Lab 5. 5.1 It would rise, from 9.3 to 9.9, because an attack that needs no user action is easier to carry out. 5.2 The vector shows *why* the score is what it is, lets a reviewer recompute it, and reveals errors that a bare number hides. 5.3 Example: S21, accidental disclosure by staff — there is no technical vulnerability to exploit; any score describes a representative weakness only.

Lab 6. 6.1 X has the higher estimated risk (4.5 times Y's); their pre-treatment ratios are equal, because probabilities cancel in the ratio. 6.2 Both are multiplied by 10; the ratio does not change. 6.3 The formula combines dimensionless probabilities, a 0–10 severity, 0–1 damage and criticality and a scaling factor; it is a relative indicator for ranking and comparison.

Lab 7. 7.1 Zero, because mitigation multiplies the two reductions. The package must also reduce impact (for example tested recovery, segmentation, detection). 7.2 Allocate a share to each of the seven scenarios (for example $180,000 ÷ 7 ≈ $25,714 each, plus a share of the recurring cost) for scenario analysis; count $180,000 once in the portfolio total. 7.3 Its effect is already in the current state (it shapes Pb(ψ,A) and θ); claiming it again counts the same reduction twice.

Lab 8. 8.1 Whether S1 can be accepted with the planned package (lower and central case) or needs stronger treatment, transfer or formal Board acceptance (higher case). 8.2 No. It means your estimates are consistent with each other, not that they are correct. 8.3 θ divides both Re and Rt, so it cancels in the ratio.

Lab 9. 9.1 It has no measure, source, owner, frequency or threshold; nobody can tell when to act. 9.2 Because a breach occurs when the value rises above the threshold (for example a click rate above 8%). 9.3 Four readings; fewer points cannot establish a trend, and a line through three points would give a false sense of precision.

Lab 10. 10.1 Executives read the first paragraph to decide whether to read the rest; the memo exists to obtain a decision. 10.2 Recalculate the workbook, find which figure is correct and correct every document so that they agree; inconsistent numbers undermine the whole recommendation. 10.3 The accountable executive or the Board, according to the delegation of authority (in MediBec's case, residual risk above 0.40 normalized requires Board acceptance).

Lab 11. 11.1 No. A source confidence is the producer's statement about the indicator, not a probability that the threat will act against MediBec. 11.2 A confirmation by a named person on a date (*Confirm as incident*). 11.3 A rule cannot detect events it never receives; coverage is validated only by an effective detection test with healthy telemetry.

Lab 12. 12.1 It tests existence, not operation. Operating effectiveness requires evidence that reviews were performed over a period, on a sample, with exceptions resolved. 12.2 Example: "System owners must enforce multi-factor authentication for all remote access to systems that process patient information, as specified in the Authentication Standard." 12.3 In the Authentication (or Password) Standard, because technical values change faster than policy and must be updated without re-approving the policy.

Appendix E — Glossary

Appetite — the amount of cybersecurity risk management is willing to pursue or retain, on a 0–1 scale. **Causal chain** — the sequence threat source → weakness → asset → event → consequence that defines a scenario. **Crown jewels** — the assets and services whose loss would most harm the mission. **CVSS v4.0 Base (CVSS-B)** — the technical severity score of one vulnerability, 0–10. **Estimated risk** — the risk of a scenario before treatment, as computed by the CRG formula. **KRI** — key risk indicator: a measured value with thresholds that signal a change in risk. **Mitigated risk** — the part of estimated risk removed by treatment. **Residual risk** — the risk that remains after treatment. **Resilience (θ)** — the demonstrated ability to prevent, detect, contain, respond, recover and maintain critical operations. **Tolerated risk** — the appetite applied to a specific scenario through the CRG formula. **Shared control** — one initiative that reduces several scenarios; its cost is counted once in the portfolio.

© 2026 Marc-André Léger. Licensed under CC BY-NC 4.0. MediBec is a fictional organization. All parameter values are illustrative analytical estimates for teaching.